



Roles, Permissions & User Administration

Adventure Bakery Team App

Audience: Application administrators & owners, and technical staff responsible for AI / code changes. **Version 1.0 · July 2026**

This guide explains how access control works, how to invite and maintain users and their roles, and how the system is built for engineers. A one-page cheat sheet and a troubleshooting table are included at the end.

1 How Access Works

Two portals, one account system

The app has a **Brand Portal** (external CPG clients) and a **Team Portal** (internal staff and external auditors). A person's **role(s)** decide which portal and which pages they can reach.

The five roles

- **Owner** — full control, including Finance. The only role that can grant Owner or Admin.
- **Admin** — manages SOPs, forms, training, and users (except granting Owner/Admin). Can do everything Staff can.
- **Staff** — fills out forms, takes assigned training, views SOPs and reports. Cannot edit master documents or manage users.
- **Auditor** — **read-only** access to the compliance system only (for the external SQF certification review). Cannot create, edit, fill forms, or be assigned training.
- **Client** (“user”) — Brand Portal only; has no Team Portal access.

Two important rules

- **A person can hold several roles at once, and permissions add together.** Roles only ever *grant* access — adding a role never removes anything. (So to keep an Auditor read-only, Auditor must be their *only* role.)
- **Security is enforced in the database**, not just the screen. Even if a button were somehow shown, the database (Row-Level Security) blocks any action the role isn't allowed to perform.

2 Permission Matrix

A quick view of what each role can do. “View” means read-only; “Manage” means create/edit/delete.

Capability	Owner	Admin	Staff	Auditor	Client
Sign in to Team Portal	Yes	Yes	Yes	Yes	No
View SOPs, forms, reports, training	Yes	Yes	Yes	Yes	No
Manage SOPs / master documents	Yes	Yes	No	No	No
Fill out & submit forms	Yes	Yes	Yes	No	No

Capability	Owner	Admin	Staff	Auditor	Client
Be assigned training	Yes	Yes	Yes	No	No
Sales / Operations / Inventory	Yes	Yes	Yes	No	No
Finance	Yes	No	No	No	No
Invite users & change roles	Yes	Limited	No	No	No
Grant Owner / Admin role	Yes	No	No	No	No
Brand Portal (client)	Yes	Yes	Yes	No	Yes

"Limited" = an Admin can invite/assign Staff, Auditor, and Client, but cannot create another Admin or Owner.

3 Administrator Guide

3.1 Invite a new team member (recommended)

The self-serve invite creates the account and applies the role/department automatically.

- Go to **HR** → **Team Directory** and click **Invite Team Member** (Owner/Admin only).
- Enter their **email**, choose a **Role** and (for staff) a **Department**, then **Create Invite**.
- The link is emailed automatically and copied to your clipboard — you can also paste it from the **Pending Invitations** list. Links expire after 7 days.
- The person opens the link, sets their own password, and is dropped into the right portal with their role and department already applied. Staff immediately begin receiving department-based training.

Never send or ask for passwords — the invitee always sets their own.

3.2 Invite the SQF auditor (read-only contractor)

- Same steps as above, but choose the **Auditor** role. Leave Department blank (auditors take no training).
- The auditor lands on the SOPs Library and can browse SOPs, forms and their entries, reports, the Document Register, Temperature Logs, and training material — all read-only. No Save/New/Submit controls appear.
- Do not also give an auditor the Staff role, or the combined permissions would let them edit.

3.3 Change or maintain a user's roles

- Go to **HR** → **Team Directory** and click the person's row (Owner/Admin only).
- Under **Roles**, tick or untick roles and click **Save Changes**. Owner and Admin checkboxes are only enabled for an Owner.
- Set the **Department** here too — changing it re-syncs that person's assigned training automatically.

A person not yet in the directory (e.g., a brand-new account) can still be opened directly at `/team/member/<their-user-id>`; once they hold a team role they appear in the list.

3.4 Manage pending invitations

- The **Pending Invitations** card (below the member list) shows everyone who hasn't accepted yet.
- **Copy link** re-copies the accept URL to send again. **Revoke** immediately invalidates a link.
- Once accepted, the person moves up into the member table; revoked or expired invites drop off the list.

3.5 Assign training

- **Automatic (default):** set a person's **Department**; they are auto-assigned every active module whose required departments include theirs, with a due date. This is the normal path.
- **Manual (extra):** **HR** → **Training Compliance** → **Assign Training** lets an Admin hand-pick modules for specific people. It never removes or duplicates existing assignments.

3.6 Create an account without an invite (fallback)

- In **Supabase** → **Authentication** → **Users** → **Add user**, enter the email and a temporary password.
- Copy the new user's **UID**, open **/team/member/<UID>** in the app, set roles + department, and Save.

4 Administrator Cheat Sheet

Everyday tasks and where to do them.

Task	Where / How
Invite a staff member	HR → Team Directory → Invite Team Member → pick Staff + Department
Invite the SQF auditor	Invite Team Member → Role = Auditor, no Department
Promote someone to Admin	Team Directory → open member → tick Admin → Save (Owner only)
Make someone read-only	Give them only the Auditor role (remove all others)
Change a department	Team Directory → open member → Department → Save (re-syncs training)
Resend an invite link	Team Directory → Pending Invitations → Copy link
Cancel an invite	Pending Invitations → Revoke
Assign a specific training	HR → Training Compliance → Assign Training
See who hasn't trained	HR → Training Compliance (matrix + overdue/expiring)
Remove a person's access	Team Directory → open member → untick all roles → Save

Role quick reference

Role	In one line
Owner	Everything, incl. Finance. Grants any role.
Admin	Runs the QMS & users; no Finance; can't grant Owner/Admin.
Staff	Fills forms, takes training, views documents.
Auditor	Read-only compliance access. Give it alone.
Client	Brand Portal only.

Golden rules

- Roles **add** permissions — they never take them away.
- Only an **Owner** can create an Owner or Admin.
- **Department** drives automatic training. Set it for every staff member.
- Invite links expire in **7 days**; invitees always set their own password.

5 Technical Reference (AI / Engineering)

The access model is standard Supabase RBAC: a **user_roles** table + SECURITY-DEFINER helper functions enforcing **Row-Level Security (RLS)**, with React gating on top. Do not add a third-party authorization library — extend this model.

5.1 Data model & SQL helpers

- **user_roles**(user_id, role) — **UNIQUE(user_id, role)**, so one row per role = native multi-role. role is **text**: owner | admin | staff | auditor | user.
- **client_invitations**(email, token, invite_kind, role, department, expires_at, accepted_at, invited_by).

SQL function	Returns true for
has_role(uid, role)	user holding exactly that role
is_owner(uid)	owner
is_staff_or_admin(uid)	owner, admin, or staff
is_compliance_viewer(uid)	is_staff_or_admin OR auditor (read gate)

Auditor is deliberately **outside** is_staff_or_admin, so every write policy already excludes it. Read policies on the compliance tables use is_compliance_viewer to let auditors *read*.

5.2 Key files

File	Responsibility
src/hooks/useUserRole.ts	Returns roles[] + hasRole(); back-compatible derived role (highest privilege)
src/components/ProtectedRoute.tsx	Route gate: allowedRoles intersected with the user's role set
src/components/TeamLayout.tsx	Sidebar; items tagged auditorOk drive the auditor-only nav
src/pages/TeamMemberDetail.tsx	Role editor (multi-select, owner-guarded) + department
src/pages/team/hr/HrDirectory.tsx	Directory, Invite dialog, Pending Invitations
src/pages/team/hr/TrainingCompliance.tsx	Manual Assign-Training dialog
src/pages/AcceptInvite.tsx	Accept flow; branches team vs client
src/lib/training.ts	assignModulesToEmployees() + department auto-sync helpers

5.3 Invitation RPCs

Function	Purpose
create_team_invitation(_email,_role,_department) → token	Admin/Owner only; owner-guarded for Owner/Admin grants. Inserts the invite, returns token.
accept_team_invitation(_token,_user_id) → role	On sign-up: marks accepted, grants the role, sets department (fires training sync).
validate_invitation_token(_token) → {email, expired, invite_kind, role, department}	Read by the accept page to render the right portal.

5.4 Migrations (Supabase)

- 20260714000001_auditor_role.sql — auditor role, is_compliance_viewer, compliance read policies, tightened user_roles write policies (owner-guarded).
- 20260714000002_team_invitations.sql — invite columns + the three RPCs above.
- 20260714000003_fix_client_invitations_defaults.sql — restores drifted column defaults (id/token/created_at/expires_at). **Applied directly via the API** during debugging; re-running is idempotent.

Deploy with `supabase db push`. The user runs migrations; deliver DB changes as migration files.

5.5 How to add a new role or gate

- Add the value to the **AppRole** union in `useUserRole.ts`.
- Add DB read/write RLS policies (reuse a helper like `is_compliance_viewer`; add one if needed).
- Add the role to **allowedRoles** on the relevant routes in `App.tsx`.
- Gate the sidebar in `TeamLayout.tsx` and add it to **ROLE_OPTIONS** in `TeamMemberDetail.tsx`.

```
-- read gate pattern (compliance tables)
USING ( public.is_compliance_viewer(auth.uid()) )
-- write stays admin/owner, so a read-only role can never write
USING ( public.has_role(auth.uid(), 'admin') OR public.is_owner(auth.uid()) )
```

6 Troubleshooting

Symptom	Cause	Fix
"Server didn't return an invite token"	client_invitations lost its column defaults (schema drift) — token inserts as NULL.	Apply migration ...00003. (Resolved 2026-07-14.)
Auditor logs in but pages are blank / won't open	Auditor migration ...00001 not deployed, so is_compliance_viewer / read policies are missing.	Run <code>supabase db push</code> to deploy ...00001.
Invited person isn't in the directory	They haven't accepted yet, or hold no team role.	Check Pending Invitations, or open <code>/team/member/</code> directly.
"Only an owner can invite an owner or admin"	An Admin tried to grant Owner/Admin.	Have an Owner perform the grant.
New staff has no training assigned	Their department is blank, or modules have no required departments.	Set the department; confirm module "required for" settings.
Invite email never arrived	The send-invitation-email edge function isn't configured.	Use Copy link and send it manually.
Auditor can edit something	They also hold Staff/Admin (roles are additive).	Remove the other roles — Auditor must be alone.